

Web Reconnaissance and Enumeration Assessment of scanme.nmap.org

Executive Summary

This assessment was conducted against scanme.nmap.org, an authorized training target provided by the Nmap Project. The objective was to perform reconnaissance and enumeration activities to identify exposed services, technologies, directories, and security configurations while following a structured penetration testing methodology. The assessment identified SSH and HTTP services running on an Ubuntu-based server. No critical vulnerabilities were identified; however, several informational findings and security observations were documented.

Scope

Target: scanme.nmap.org

Assessment Type: Reconnaissance and Enumeration

Methodology

1. Host Discovery
2. Service Enumeration
3. Operating System Fingerprinting
4. Web Server Analysis
5. Directory Enumeration
6. HTTP Method Analysis
7. Security Header Review
8. Documentation of Findings

Tools Used

- Nmap
- Gobuster
- Curl
- Kali Linux

Technical Findings

1. Service Enumeration

Nmap service detection identified SSH, HTTP, and Nping Echo services. The target appeared to be running Ubuntu Linux with Apache 2.4.7.

Port	Service	Observation
------	---------	-------------

22	SSH	OpenSSH 6.6.1p1
80	HTTP	Apache 2.4.7
9929	Nping Echo	Nmap testing service

2. Web Server Analysis

HTTP header analysis confirmed Apache/2.4.7 (Ubuntu). The server disclosed version information through response headers.

3. Directory Enumeration

Directory enumeration identified /.svn, /images, and /shared. Sensitive files such as .htaccess and .htpasswd were present but protected with HTTP 403 responses.

4. SVN Directory Verification

The /.svn directory returned HTTP 403 Forbidden, indicating that the directory exists but is not publicly accessible. No source code exposure was observed.

5. HTTP Method Analysis

The server supported GET, HEAD, POST, and OPTIONS methods. Potentially risky methods such as PUT, DELETE, TRACE, and CONNECT were not enabled.

6. Security Header Review

Common security headers such as Content-Security-Policy, X-Frame-Options, Strict-Transport-Security, X-Content-Type-Options, and Referrer-Policy were not observed.

Findings Summary

ID	Finding	Severity
F-01	Server Version Disclosure	Low
F-02	Missing Security Headers	Low
F-03	SVN Directory Present but Protected	Informational
F-04	Sensitive Files Properly Protected	Good Practice
F-05	No Dangerous HTTP Methods Enabled	Good Practice

Recommendations

- Disable version disclosure in HTTP response headers where possible.
- Implement Content Security Policy (CSP).
- Implement HSTS for HTTPS deployments.

- Configure X-Frame-Options and X-Content-Type-Options.
- Continue restricting access to sensitive files and directories.

Conclusion

The assessment successfully demonstrated the reconnaissance and enumeration phases of a penetration test. The target exposed limited information and appeared to be reasonably hardened for its intended purpose as a public training target.